

보안관제 포트폴리오 프로젝트 요구 사항 정의서 v1.0

프로젝트명: SOC Detection & Monitoring Lab

문서유형: Software/System Requirements Specification

문서버전: v1.0

기준일: 2026-08-24

프로젝트 목적: 보안관제 직무 지원용 실무형 포트폴리오 구축

1. 문서 개요

1.1 목적

본 문서는 Suricata, Snort, SIEM 및 로그 분석 기술을 기반으로 한 **보안관제 실습 플랫폼**의 요구사항을 정의한다.

본 프로젝트의 최종 목적은 단순한 보안솔루션 설치가 아니라 다음 End-to-End 보안관제 Workflow를 직접 구현하고 검증하는 것이다.

```
Attack / Suspicious Traffic
  ↓
Network Traffic
  ↓
IDS Sensor
  ↓
Detection Rule
  ↓
Security Event
  ↓
Log Collection
  ↓
SIEM
  ↓
Alert
  ↓
SOC Analyst Triage
  ↓
Investigation
  ↓
True / False Positive
  ↓
Response
  ↓
```

Detection Tuning
↓
Incident Report
↓
Portfolio Evidence

2. 프로젝트 개요

본 시스템은 격리된 Lab 환경에서 발생하는 네트워크 트래픽을 IDS가 분석하고 탐지 결과를 SIEM으로 전달하여 SOC Analyst가 조사할 수 있도록 구성하는 **Security Monitoring Lab**이다.

핵심 구성 요소는 다음과 같다.

- Attacker/Test Client
- Victim Server
- Suricata
- Snort
- Log Collector
- SIEM
- Dashboard
- SOC Analyst
- Detection Rules
- MITRE ATT&CK Mapping
- PCAP
- Incident Report
- Portfolio Evidence

3. 프로젝트 배경

보안관제 직무는 단순히 경보를 확인하는 직무가 아니다.

다음 역량이 복합적으로 요구된다.

- TCP/IP

- Network Protocol
- Packet 분석
- IDS/IPS
- SIEM
- Log 분석
- Detection Rule
- IOC
- Event Correlation
- Triage
- False Positive 판별
- Incident Analysis
- Detection Tuning
- 보고서 작성

따라서 프로젝트 역시 단순히

|"Suricata를 설치했다."

에서 끝나지 않고,

|"공격 트래픽이 어떤 탐지 규칙에 의해 탐지되었으며, 생성된 Event의 어떤 필드를 근거로 실제 공격 여부를 판단하였고, 오탐 가능성을 어떻게 검토하여 탐지 정책을 개선했는가."

까지 설명할 수 있도록 구축한다.

4. 프로젝트 목적

4.1 기술적 목적

1. IDS/IPS 동작 원리 이해
2. Suricata 운용 능력 확보
3. Snort 운용 능력 확보
4. IDS Rule 이해 및 작성

5. 네트워크 패킷 분석
6. Security Event 분석
7. SIEM 기반 로그 검색
8. Alert Investigation
9. MITRE ATT&CK Mapping
10. Detection Rule Tuning

4.2 포트폴리오 목적

채용담당자 또는 보안관제 실무자가 GitHub Repository를 확인하였을 때 다음 역량을 판단할 수 있도록 한다.

- 네트워크 이해
 - IDS/IPS 이해
 - 로그 분석 능력
 - SIEM 사용 능력
 - 탐지 근거 설명 능력
 - 보안사고 초동분석 능력
 - 오탐 판별 능력
 - 문제해결 능력
 - 기술 문서화 능력
-

5. Portfolio 목표

최종 포트폴리오는 다음 질문에 답할 수 있어야 한다.

Q1. 무엇을 탐지했는가?

공격 또는 이상 트래픽 유형을 설명한다.

Q2. 왜 탐지되었는가?

탐지 Rule과 조건을 설명한다.

Q3. 어떤 로그가 생성되었는가?

Raw Event를 제시한다.

Q4. 로그에서 무엇을 확인했는가?

Source/Destination, Protocol, Signature 등을 분석한다.

Q5. 실제 공격인가?

True Positive / False Positive를 판단한다.

Q6. ATT&CK에서는 무엇에 해당하는가?

관련 Technique을 연결한다.

Q7. 어떤 대응이 필요한가?

SOC Analyst 관점의 대응방안을 제시한다.

Q8. 탐지정책은 개선할 필요가 있는가?

Rule Tuning 결과를 제시한다.

6. 프로젝트 범위

6.1 P0 — Portfolio Core

반드시 구현한다.

- Suricata
- Snort
- 격리된 Attack Lab
- Victim System
- IDS Rule
- Custom Rule
- Alert
- Raw Log
- Log 분석
- PCAP 분석

- Incident Analysis
- Portfolio Evidence

6.2 P1 — SOC Platform

MVP 이후 구축한다.

- Wazuh 기반 로그 관리
- SIEM Dashboard
- Alert Search
- MITRE ATT&CK
- Detection Rule 관리
- False Positive Tuning
- IOC Analysis
- Incident Report

6.3 P2 — Advanced

확장 단계에서 적용한다.

- Zeek
- Sigma
- YARA
- Threat Intelligence
- IOC Enrichment
- Alert Correlation
- Detection-as-Code
- Rule CI/CD
- SOAR 개념

7. 기술 Baseline

2026년 8월 24일 현재 프로젝트 기준선은 다음과 같이 설정한다.

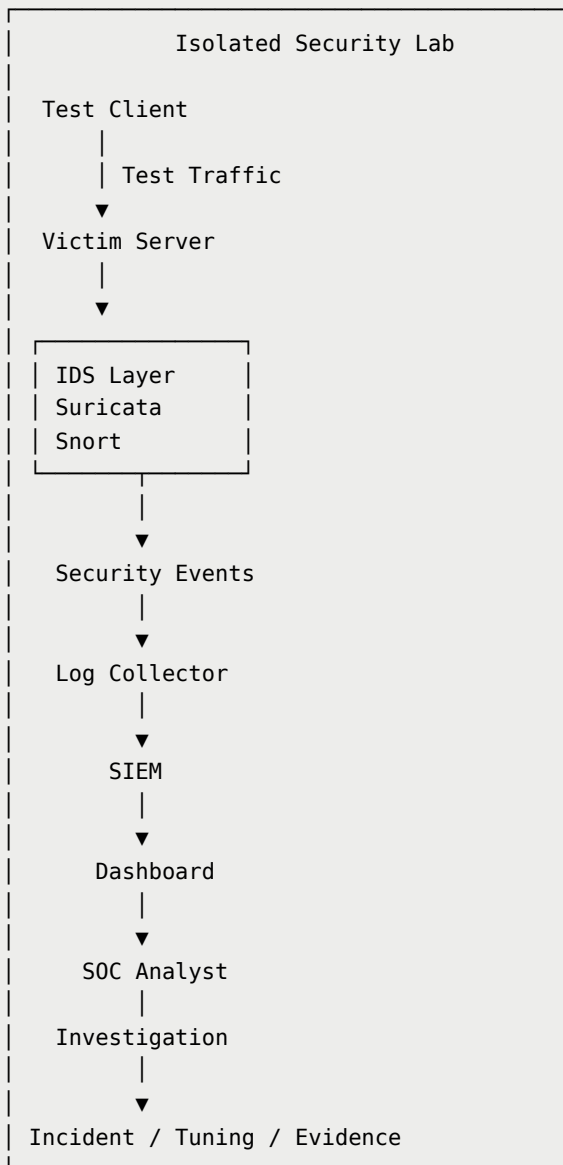
영역	Baseline
Primary IDS	Suricata 8.x
Suricata 확인 버전	8.0.6
Secondary IDS	Snort 3
Snort 확인 버전	3.12.2.0
SIEM 후보	Wazuh
Wazuh 확인 버전	4.14.7
검색 플랫폼 후보	OpenSearch
OpenSearch 확인 버전	3.8
NSM 확장	Zeek
Zeek 현재 Feature Release	8.2
ATT&CK	MITRE ATT&CK 19.2

Suricata 8.0.6은 2026년 7월 공개되었으며 Suricata 7 계열은 EOL 상태다. Snort 공식 다운로드 페이지에는 Snort 3.12.2.0이 제공되고 있다. Wazuh 현재 공식 패키지는 4.14.7이며 Wazuh Server, Indexer, Dashboard 구조를 유지한다. OpenSearch는 2026년 8월 4일 3.8을 공개했고, Zeek 8.2는 현재 Feature Release이며 Zeek 9.0은 2026년 8월 31일 출시 예정이므로 본 Baseline에서는 제외한다. MITRE ATT&CK 사이트는 2026년 8월 6일 기준 Content Version 19.2를 제공한다.

8. 이해관계자

Actor	역할
Security Analyst	Alert 분석, Triage 및 사고 판정
Security Engineer	IDS/SIEM 및 Detection Rule 관리
Administrator	시스템 및 계정 관리
Test Client	합법적 공격·이상 Traffic Simulation
Victim System	공격 시뮬레이션 대상
Portfolio Reviewer	프로젝트 구현 및 분석능력 평가

9. 시스템 전체 구성



10. 주요 Use Case

ID	Use Case
UC-001	Network Traffic Monitoring
UC-002	IDS Signature Detection
UC-003	Custom Rule Detection
UC-004	PCAP Offline Analysis
UC-005	Security Log Collection

ID	Use Case
UC-006	SIEM Event Search
UC-007	Alert Triage
UC-008	Incident Investigation
UC-009	False Positive Analysis
UC-010	Detection Rule Tuning
UC-011	MITRE ATT&CK Mapping
UC-012	Incident Report 작성

11. 기능 요구사항

FR-IDS-001 Network Traffic Monitoring

중요도: P0

요구사항

시스템은 지정된 Network Interface를 통과하는 트래픽을 IDS를 이용하여 분석할 수 있어야 한다.

출력

- Timestamp
- Source IP
- Destination IP
- Protocol
- Source Port
- Destination Port

Acceptance Criteria

격리된 Lab에서 Test Client와 Victim 간 통신 발생 시 IDS가 해당 Traffic을 관찰할 수 있어야 한다.

Verification

Test

FR-IDS-002 Suricata Detection

중요도: P0

Suricata는 활성화된 Detection Rule과 일치하는 Traffic에 대해 Alert Event를 생성해야 한다.

Acceptance Criteria

정의된 테스트 트래픽 입력 후 Suricata EVE에서 대응 Alert를 확인할 수 있어야 한다.

Suricata EVE는 Alert뿐 아니라 HTTP, DNS, TLS 등 프로토콜별 기록을 JSON 형태로 출력할 수 있다.

FR-IDS-003 Snort Detection

중요도: P0

Snort 3는 동일 또는 유사한 테스트 Traffic에 대해 Signature 기반 분석을 수행할 수 있어야 한다.

Acceptance Criteria

사전에 정의한 Rule과 매칭되는 Traffic 발생 후 Snort Alert 결과에서 Signature를 식별할 수 있어야 한다.

FR-IDS-004 PCAP Offline Analysis

중요도: P0

Suricata 및 Snort는 저장된 PCAP에 대한 Offline Analysis가 가능해야 한다.

목적

실시간 공격을 재현하지 않고도 안전하게 악성·이상 Traffic 탐지 연습을 수행하기 위함이다.

12. Suricata 요구사항

ID	요구사항	Priority
FR-SURI-001	Network Interface Monitoring	P0
FR-SURI-002	IDS Mode	P0
FR-SURI-003	PCAP Analysis	P0

ID	요구사항	Priority
FR-SURI-004	Rule Loading	P0
FR-SURI-005	Custom Rule	P0
FR-SURI-006	EVE JSON Logging	P0
FR-SURI-007	Alert Event	P0
FR-SURI-008	HTTP Event	P1
FR-SURI-009	DNS Event	P1
FR-SURI-010	TLS Event	P1
FR-SURI-011	Flow Event	P1
FR-SURI-012	SID 관리	P0
FR-SURI-013	Rule Revision 관리	P1

EVE를 SIEM 연계의 주된 데이터 소스로 사용한다.

원본 `eve.json` 구조는 변경하지 않는다.

별도 Normalization이 필요한 경우 Collector 또는 SIEM 계층에서 처리한다.

13. Snort 요구사항

ID	요구사항	Priority
FR-SNORT-001	Snort 3 실행	P0
FR-SNORT-002	Traffic Monitoring	P0
FR-SNORT-003	PCAP Analysis	P0
FR-SNORT-004	Community Rule 적용	P0
FR-SNORT-005	Custom Rule	P0
FR-SNORT-006	Alert 생성	P0
FR-SNORT-007	SID 확인	P0
FR-SNORT-008	Protocol 확인	P0
FR-SNORT-009	Src/Dst 분석	P0
FR-SNORT-010	Suricata 결과 비교	P1

14. IDS/IPS 공통 요구사항

시스템은 Suricata와 Snort에서 최소 다음 항목을 비교할 수 있어야 한다.

비교항목	검증내용
Architecture	처리구조 차이
Rule	Rule Syntax 및 호환성
Traffic 처리	실시간 Traffic 처리
PCAP	Offline 분석
Logging	출력 형식
Protocol	Protocol 식별
Alert	경보 생성 구조
Performance	Lab 환경 Resource 사용량
Tuning	오탐 조정 방식
SIEM	외부 Log Platform 연계

15. 공격 Simulation 요구사항

모든 시뮬레이션은 격리된 **Local Lab** 또는 명시적으로 허가된 대상에서만 수행한다.

외부 시스템을 대상으로 한 스캔·공격은 프로젝트 범위에서 제외한다.

ID	Scenario	목적
ATK-001	ICMP Scan	기본 Network 탐지
ATK-002	TCP SYN Scan	Scan Detection
ATK-003	Port Scan	Reconnaissance 탐지
ATK-004	Service Enumeration	서비스 탐색 분석
ATK-005	SSH Login Failure	인증 실패 분석
ATK-006	Brute Force Simulation	반복 인증 Event 분석
ATK-007	Suspicious HTTP Request	Web Traffic 분석
ATK-008	SQL Injection Test Pattern	Web IDS Rule 분석
ATK-009	XSS Test Pattern	Web Payload 탐지
ATK-010	Directory Traversal Pattern	Web Attack 탐지
ATK-011	Suspicious DNS	DNS Event 분석
ATK-012	Malware PCAP	Offline 악성 Traffic 분석

각 Scenario는 다음 절차로 검증한다.

```
Scenario
→ Traffic
→ IDS
→ Detection Rule
→ Raw Event
→ SIEM
→ Analyst
→ ATT&CK
→ Verdict
→ Response
→ Evidence
```

16. Detection Rule 요구사항

FR-RULE-001 Custom Rule

사용자는 Suricata 또는 Snort Custom Rule을 생성할 수 있어야 한다.

각 Rule에는 최소 다음 Metadata를 관리한다.

```
Rule ID
Engine
SID
REV
Name
Category
Severity
Protocol
Detection Condition
MITRE ATT&CK
False Positive
Validation PCAP
Author
Created
Modified
Status
```

FR-RULE-002 Rule Lifecycle

Rule은 다음 Lifecycle을 따른다.

```
DRAFT
↓
TEST
```

↓
VALIDATED
↓
DEPLOYED
↓
MONITORING
↓
TUNED
↓
DEPRECATED

FR-RULE-003 Git Version Control

Rule 변경 이력을 Git Commit으로 추적할 수 있어야 한다.

Acceptance Criteria

Rule 수정 후 다음 내용을 확인할 수 있어야 한다.

- 변경 전 Rule
- 변경 후 Rule
- 변경 이유
- Test 결과
- Commit ID

17. 로그 관리 요구사항

최소 다음 데이터를 관리한다.

- Suricata EVE
- Suricata Alert
- Snort Alert
- Authentication Log
- Web Log
- DNS Event
- Network Flow
- SIEM Alert

- Incident Analysis

18. 공통 Event Model

Normalization 계층의 공통 데이터 모델은 다음을 기본으로 한다.

```
{
  "timestamp": "",
  "sensor": "",
  "event_type": "",
  "src_ip": "",
  "src_port": null,
  "dest_ip": "",
  "dest_port": null,
  "protocol": "",
  "signature": "",
  "signature_id": "",
  "severity": "",
  "category": "",
  "mitre_technique": "",
  "raw_event": {}
}
```

원본 Event는 별도로 보존한다.

19. SIEM 요구사항

FR-SIEM-001 Event Ingestion

SIEM은 IDS Event를 수집할 수 있어야 한다.

FR-SIEM-002 Search

Analyst는 최소 다음 필드로 Event를 검색할 수 있어야 한다.

- Timestamp
- Source IP

- Destination IP
- Protocol
- Signature
- SID
- Severity

FR-SIEM-003 Dashboard

Dashboard는 Event의 전체 현황을 시각화할 수 있어야 한다.

FR-SIEM-004 Raw Event

가공된 Alert에서 원본 Event를 추적할 수 있어야 한다.

20. SIEM Baseline 결정

MVP 이후 첫 SIEM은 **Wazuh**를 우선 적용한다.

Wazuh 공식 구조는 Wazuh Agent와 중앙의 **Wazuh Server**, **Wazuh Indexer**, **Wazuh Dashboard**로 구성되며, Server가 데이터를 분석하고 Indexer가 Alert를 색인·저장한다. Wazuh Server 내 Filebeat가 Event와 Alert를 Indexer로 전달하는 구조가 공식 문서에 명시되어 있다.

선정 이유

- 무료/Open Source 중심 Lab 구축 가능
- Endpoint Log와 Network IDS Event를 함께 연습 가능
- Rule/Decoder 학습 가능
- Dashboard 제공
- SOC Portfolio와 연계하기 쉬움

OpenSearch는 차기 확장 또는 별도 SIEM/Search 실습 대상으로 고려한다.

21. Alert 관리 요구사항

Alert Lifecycle은 다음 상태를 기본으로 한다.

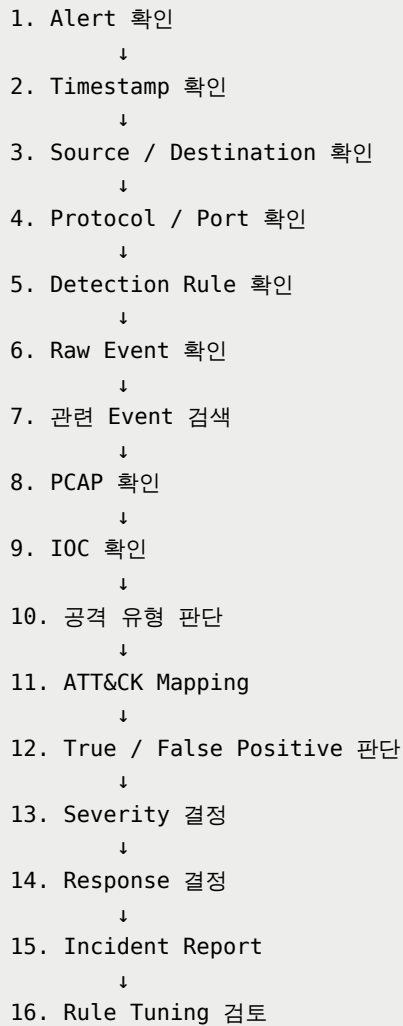

```
NEW
↓
TRIAGE
↓
INVESTIGATING
├─ TRUE_POSITIVE
├─ FALSE_POSITIVE
└─ BENIGN
↓
CLOSED
```

각 Alert에는 다음 Field가 있어야 한다.

- Alert ID
- Timestamp
- Sensor
- Signature
- SID
- Source
- Destination
- Protocol
- Severity
- Raw Event
- Analyst
- ATT&CK
- IOC
- Verdict
- Analysis
- Response
- Status

22. SOC Analyst Workflow

분석자는 다음 순서로 Alert를 분석한다.



23. Dashboard 요구사항

최소 다음 Visualization을 제공한다.

- Total Alerts
- Alerts over Time
- Severity Distribution
- Top Source IP
- Top Destination IP
- Top Signature
- Attack Category

- Protocol Distribution
- Detection Rule Count
- True Positive
- False Positive
- ATT&CK Technique
- Sensor Status

24. Incident 분석 요구사항

각 Incident Report에는 다음 내용이 포함되어야 한다.

```
Incident ID
Date/Time
Detection Source
Alert
Summary
Source
Destination
Protocol
Raw Evidence
Rule
ATT&CK Mapping
Analysis
Verdict
Severity
Impact
Response
Detection Improvement
Evidence
```

25. MITRE ATT&CK 요구사항

Detection Rule 또는 Incident에는 관련 ATT&CK Technique을 연결할 수 있어야 한다.

기본 Metadata:

```
Tactic
Technique ID
Technique Name
Sub-technique
```

ATT&CK는 현재 19.2 데이터 기준으로 참조한다.

26. 비기능 요구사항

NFR-PERF-001

일반적인 개인용 Lab 환경에서 주요 구성요소가 동시에 실행 가능해야 한다.

NFR-PERF-002

Alert 검색은 실습 데이터 규모에서 사용자 분석 흐름을 방해하지 않는 수준으로 제공되어야 한다.

NFR-AVAIL-001

주요 Component에 Health Check 방법이 존재해야 한다.

NFR-MAIN-001

Configuration은 Source Code와 분리한다.

NFR-MAIN-002

Rule은 Git으로 관리한다.

NFR-PORT-001

프로젝트는 가능한 범위에서 Docker 또는 표준 Linux 환경으로 재현 가능해야 한다.

27. Security 요구사항

ID	요구사항
SEC-001	Default Password 사용 금지
SEC-002	Hardcoded Credential 금지
SEC-003	Secret Git Commit 금지

ID	요구사항
SEC-004	최소권한 적용
SEC-005	불필요 Port 차단
SEC-006	Management Interface 접근 제한
SEC-007	Log 접근권한 제한
SEC-008	관리자와 Analyst 역할 분리
SEC-009	Audit Log 유지
SEC-010	Container Root 권한 최소화
SEC-011	Lab Network 외부 Attack 금지
SEC-012	개인정보·실제 기밀정보 사용 금지

28. 운영 요구사항

- 시스템 시작/종료 절차를 문서화한다.
- IDS Rule Update 절차를 기록한다.
- SIEM 상태점검 절차를 기록한다.
- Log Storage 사용량을 점검한다.
- 장애 발생 시 Troubleshooting 기록을 남긴다.
- Version Upgrade 이전 Backup 또는 Rollback 방법을 정의한다.

29. 테스트 요구사항

TC-IDS-001 Suricata Traffic Capture

Given

Attacker와 Victim 시스템이 정상 통신한다.

When

테스트 Traffic을 발생시킨다.

Then

Suricata가 해당 Traffic을 관찰해야 한다.

TC-IDS-002 Suricata Rule Detection

When

사전에 정의한 Rule과 매칭되는 Traffic이 발생한다.

Then

EVE Alert가 생성되어야 한다.

TC-IDS-003 Snort Detection

동일한 테스트 Traffic에 대해 Snort Alert 존재 여부를 확인한다.

TC-LOG-001 Log Collection

IDS Event 생성 후 Collector 또는 SIEM에서 동일 Event를 확인한다.

TC-SIEM-001 Search

Source IP를 기준으로 관련 Alert를 검색할 수 있어야 한다.

TC-ANALYSIS-001 Analyst Investigation

Alert 하나를 선택하여 다음을 모두 식별한다.

- Source
 - Destination
 - Protocol
 - Signature
 - Rule
 - Raw Event
 - ATT&CK
 - Verdict
-

TC-RULE-001 Custom Rule

Custom Rule과 일치하는 Test Traffic 발생 시 의도한 Alert가 발생해야 한다.

TC-RULE-002 False Positive Tuning

오탐 Scenario에 대해 Rule을 수정하고 재시험한 결과,

- 정상 Traffic 경보 감소
- 목표 Attack Traffic Detection 유지

를 증명해야 한다.

30. Requirements Traceability Matrix

Requirement	Test	Evidence	Priority
FR-IDS-001	TC-IDS-001	EV-001	P0
FR-IDS-002	TC-IDS-002	EV-002	P0
FR-IDS-003	TC-IDS-003	EV-003	P0
FR-RULE-001	TC-RULE-001	EV-004	P0
FR-LOG-001	TC-LOG-001	EV-005	P0
FR-SIEM-001	TC-LOG-001	EV-006	P1
FR-SIEM-002	TC-SIEM-001	EV-007	P1
FR-ANALYSIS-001	TC-ANALYSIS-001	EV-008	P0
FR-RULE-003	Inspection	EV-009	P1
FR-RULE-TUNE	TC-RULE-002	EV-010	P1

31. Portfolio Evidence 요구사항

Evidence	내용
EV-001	Network Traffic Capture
EV-002	Suricata Alert
EV-003	Snort Alert
EV-004	Custom Rule
EV-005	Raw Log
EV-006	SIEM Ingestion
EV-007	SIEM Dashboard
EV-008	Alert Investigation

Evidence	내용
EV-009	Git Rule History
EV-010	Rule Tuning
EV-011	PCAP Analysis
EV-012	MITRE ATT&CK Mapping
EV-013	Incident Report
EV-014	Architecture Diagram
EV-015	Troubleshooting Record

Evidence에는 상황에 따라 다음을 포함한다.

- Screenshot
- Command
- Configuration
- Raw Log
- PCAP
- Rule
- 분석
- 문제
- 원인
- 해결
- 결과

32. GitHub Repository 요구사항

```
soc-detection-monitoring-lab/
|
├── README.md
|
├── docs/
|   ├── requirements/
|   ├── architecture/
|   ├── design/
|   ├── installation/
|   ├── detection/
|   └── analysis/
```



```
| | incident/
| | └─ troubleshooting/
|
| └─ suricata/
| | └─ config/
| | └─ rules/
|
| └─ snort/
| | └─ config/
| | └─ rules/
|
| └─ wazuh/
|
| └─ attack-lab/
|
| └─ pcaps/
|
| └─ scripts/
|
| └─ tests/
|
| └─ evidence/
```

Repository에 Credential, Token 또는 실제 민감정보를 저장하지 않는다.

33. README 요구사항

README는 최소 다음 순서로 작성한다.

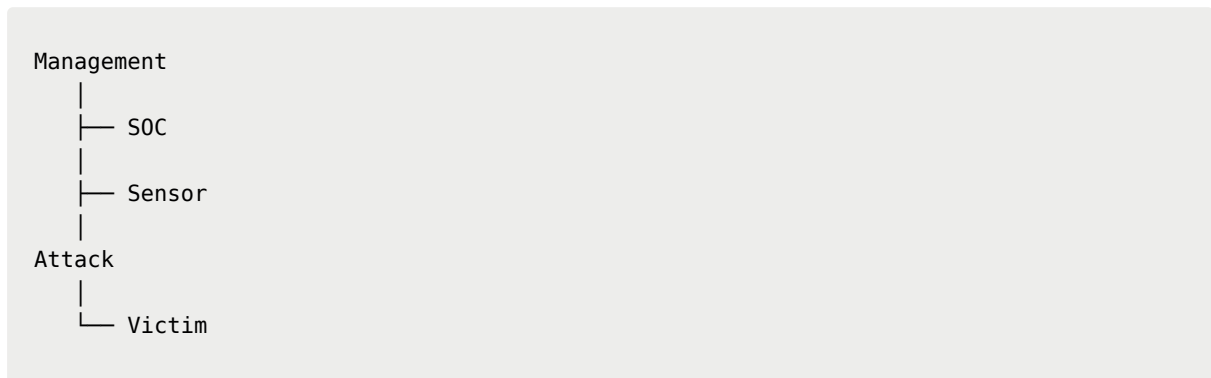
1. Project Overview
2. Objective
3. Architecture
4. Technology Stack
5. Lab Environment
6. Detection Pipeline
7. Attack Scenarios
8. Detection Rules
9. SIEM
10. Investigation Example
11. MITRE ATT&CK
12. False Positive Tuning
13. Screenshots
14. Troubleshooting
15. Lessons Learned
16. Future Improvements

34. 기술 Stack

영역	기술	역할	우선도
Primary IDS	Suricata 8	Network Detection	P0
Secondary IDS	Snort 3	IDS 비교 및 Rule 학습	P0
SIEM	Wazuh	Event 분석·검색	P1
Search	Wazuh Indexer/OpenSearch 계열	Index/Search	P1
NSM	Zeek	Network Metadata	P2
Detection	Sigma	범용 Detection Rule	P2
File Detection	YARA	Pattern Detection	P2
Framework	MITRE ATT&CK	공격행위 분류	P1
Packet	Wireshark/tshark	Packet Analysis	P0
Environment	Docker/VM	Lab 구성	P0
SCM	Git/GitHub	Rule 및 문서 Versioning	P0

35. 시스템 Architecture 요구사항

상세 Architecture는 다음 단계에서 확정하되 최소 다음 Zone을 논리적으로 분리한다.



외부 Internet과 Attack Lab 사이에는 명시적인 격리 정책을 둔다.

36. 구현 우선순위

P0

1. Lab

2. Traffic
3. Suricata
4. Snort
5. Rule
6. Alert
7. Raw Log
8. Packet Analysis
9. Investigation
10. Evidence

P1

1. Wazuh
2. Dashboard
3. ATT&CK
4. Custom Detection
5. False Positive
6. Rule Tuning
7. Incident Report

P2

1. Zeek
2. Sigma
3. YARA
4. Threat Intelligence
5. Detection-as-Code
6. Automation

37. MVP 범위

MVP 성공 기준은 다음 Pipeline의 완전한 동작이다.

```
Test Client
  ↓
Victim
  ↓
Network Traffic
  ↓
Suricata
  ↓
Detection
  ↓
eve.json
  ↓
Analyst
  ↓
Analysis
  ↓
Report
```

이 단계에서는 SIEM을 필수로 요구하지 않는다.

MVP를 먼저 완료한 후 Wazuh를 추가함으로써 문제 발생 시 IDS 자체 문제와 SIEM 연동 문제를 분리할 수 있도록 한다.

38. 확장 범위

Intermediate

```
Suricata
+
Snort
  ↓
Log Pipeline
  ↓
Wazuh
  ↓
Dashboard
  ↓
Analyst
```

Advanced

Suricata + Snort + Zeek



Central Logging



SIEM



MITRE / IOC Enrichment



Alert Correlation



Detection-as-Code

39. 프로젝트 제한사항

- 학습 및 Portfolio 목적으로 사용
- 공격 대상은 소유 또는 명시적으로 허가된 Lab으로 제한
- 외부 IP에 대한 공격 시험 금지
- 실제 Malware 실행은 기본 범위에서 제외
- 악성 Traffic은 안전한 PCAP 분석을 우선
- 개인정보 사용 금지
- 기업 내부 데이터 사용 금지
- 상용 Security Solution 의존성 최소화
- 개인 PC에서 재현 가능한 규모 유지

40. Acceptance Criteria

전체 프로젝트의 최소 완료 조건은 다음과 같다.

- ☐ Lab Network 구축
- ☐ Attacker/Test Client 동작
- ☐ Victim 동작
- ☐ Suricata Traffic Capture
- ☐ Suricata Alert
- ☐ Snort Alert

- ☐ PCAP 분석
- ☐ Custom Rule 작성
- ☐ Rule Test
- ☐ Raw Event 확보
- ☐ Source/Destination 분석
- ☐ Protocol 분석
- ☐ Signature 분석
- ☐ ATT&CK Mapping
- ☐ True Positive 분석 사례
- ☐ False Positive 분석 사례
- ☐ Rule Tuning 사례
- ☐ SIEM Event 수집
- ☐ Dashboard
- ☐ Incident Report
- ☐ Troubleshooting 기록
- ☐ Architecture Diagram
- ☐ GitHub README
- ☐ Requirements/Test/Evidence 추적
- ☐ 민감정보 Repository 미포함
- ☐ 제3자가 README만으로 프로젝트 흐름을 이해 가능

41. Portfolio 평가 Matrix

평가영역	증빙
Network	Traffic/PCAP 분석
Protocol	HTTP/DNS/TCP 분석
IDS	Suricata/Snort
Detection	Custom Rule

평가영역	증빙
SIEM	Wazuh Dashboard
Log Analysis	Raw Event 분석
SOC Triage	Alert Investigation
Threat Analysis	ATT&CK Mapping
FP Analysis	False Positive 사례
Tuning	Rule 변경 전후
Incident Response	Incident Report
Troubleshooting	장애 해결 기록
Version Control	Git History
Documentation	GitHub Repository

42. 포트폴리오 핵심 시연 Scenario 5개

Scenario 1 — Network Reconnaissance

```

Port Scan
→ IDS Alert
→ Source/Destination
→ Rule
→ PCAP
→ ATT&CK
→ Analyst Verdict

```

증명 역량: Network + IDS + Triage

Scenario 2 — Authentication Attack Simulation

```

Repeated Authentication Failure
→ Log
→ Detection
→ Correlation
→ Analyst

```

증명 역량: Event Analysis + Correlation

Scenario 3 — Suspicious Web Request

HTTP Test Pattern
→ Suricata
→ Signature
→ HTTP Metadata
→ Investigation

증명 역량: Web Security + IDS

Scenario 4 — Malware Traffic PCAP

PCAP
→ Offline IDS
→ Alert
→ Network IOC
→ Analyst Investigation

증명 역량: PCAP + Threat Analysis

Scenario 5 — False Positive Tuning

Normal Traffic
→ Alert
→ False Positive 판단
→ Rule 분석
→ Rule 수정
→ Re-test
→ 정상 Traffic Alert 감소
→ Attack Detection 유지

증명 역량: Detection Engineering

본 Portfolio에서 **가장 중요한 Scenario**로 취급한다.

43. MVP 핵심 기능 TOP 10

순위	기능
1	격리된 Attack Lab

순위	기능
2	Network Traffic Capture
3	Suricata Detection
4	Snort Detection
5	PCAP Analysis
6	Detection Rule 분석
7	Custom Rule
8	Raw Log Analysis
9	Alert Investigation
10	Portfolio Evidence

44. 권장 구축 Roadmap

Phase 0 — Lab Environment

목표: 안전한 격리환경 확보

완료조건

Attacker와 Victim 간 통신은 가능하지만 외부 공격 대상으로 사용될 수 없는 구조가 확보되어야 한다.

Phase 1 — Network Monitoring

Traffic Capture 및 PCAP 분석

Phase 2 — Suricata

Suricata 설치, Traffic Capture, EVE, Rule, Alert 검증

Phase 3 — Snort

Snort 3 설치 및 Suricata 결과 비교

Phase 4 — Attack Simulation

격리된 Scenario를 기반으로 Detection 검증

Phase 5 — Log Pipeline

IDS Event 수집 구조 구현

Phase 6 — SIEM

Wazuh 구축 및 Dashboard 연동

Phase 7 — Detection Engineering

Custom Rule 및 Detection Tuning

Phase 8 — SOC Analysis

Alert Triage 및 Incident Investigation

Phase 9 — Incident Response

대응방안 및 Incident Report

Phase 10 — Portfolio Completion

GitHub, Evidence, Architecture, README 정리

45. Definition of Done

최종 프로젝트는 단순히 모든 Container가 실행된 상태를 완료로 판단하지 않는다.

다음 하나의 End-to-End Scenario가 완전히 증명되어야 한다.

```
ATTACK
↓
TRAFFIC
↓
DETECTION
↓
RULE
↓
RAW EVENT
↓
SIEM
↓
```

ALERT
↓
TRIAGE
↓
INVESTIGATION
↓
VERDICT
↓
MITRE ATT&CK
↓
RESPONSE
↓
TUNING
↓
RE-TEST
↓
REPORT
↓
EVIDENCE

그리고 GitHub Portfolio의 독자가 다음 질문에 답할 수 있어야 한다.

무엇이 발생했고, 왜 탐지되었으며, 어떤 증거를 이용하여 판단했고, 탐지체계를 어떻게 개선했는가?

46. 최종 Portfolio 평가 기준

본 프로젝트에서 높은 평가를 받기 위한 우선순위는 다음과 같다.

보안 도구 개수
<
동작하는 시스템
<
탐지 성공
<
로그 분석
<
탐지 근거 설명
<
오탐 판별
<
Detection Tuning
<
전체 분석 과정의 증빙

따라서 Suricata, Snort, Zeek, Wazuh, Sigma, YARA를 모두 설치하는 것보다

하나의 실제 Event를 처음부터 끝까지 정확하게 분석하고 설명할 수 있는 Portfolio를 우선한다.

47. Requirements Baseline v1.0

본 문서 승인 시 다음을 Baseline으로 설정한다.

```
Project:
SOC Detection & Monitoring Lab

Primary Objective:
Security Operations Portfolio

Primary IDS:
Suricata 8.x

Secondary IDS:
Snort 3.x

Primary SIEM:
Wazuh

Network Analysis:
Wireshark / PCAP

Threat Framework:
MITRE ATT&CK

Primary Pipeline:
Traffic
→ Detection
→ Event
→ SIEM
→ Alert
→ Investigation
→ Response
→ Tuning

P0:
IDS + Traffic + Rule + Analysis + Evidence

P1:
SIEM + ATT&CK + Tuning

P2:
Zeek + Sigma + YARA + TI + Automation
```

Baseline 변경은 향후 **Architecture Decision Record(ADR)**를 남기고 수행한다.

48. 다음 단계

요구사항 정의가 완료되었으므로 다음 산출물은

「시스템 아키텍처 및 기본설계서 v1.0」

이다.

다음 단계에서는 본 요구사항을 기반으로 다음을 확정한다.

```
Requirement
↓
Architecture
↓
Component
↓
Network Topology
↓
Traffic Path
↓
Deployment Model
↓
Log Pipeline
↓
Security Boundary
```

특히 다음 항목은 요구사항 단계에서 임의로 구현하지 않고 Architecture 단계에서 먼저 결정한다.

1. Docker / VM / Hybrid 구조
2. Attacker 위치
3. Victim 위치
4. Suricata Sensor 위치
5. Snort 운영 방식
6. Traffic Mirroring 방식
7. Network Segment 및 CIDR
8. Wazuh 배치 구조
9. Log Collection 경로
10. Management Network
11. Security Boundary

- 12. Volume 및 Evidence Storage
 - 13. Component별 Resource
 - 14. Port 및 Protocol
 - 15. Git Repository 실제 구조
-

최종 프로젝트 핵심 문장

본 프로젝트는 Suricata·Snort 등 보안 도구의 설치 자체를 목표로 하지 않으며, 격리된 실습환경에서 발생한 네트워크 이벤트를 탐지하고, 탐지 Rule과 Raw Log를 근거로 분석하여 True/False Positive를 판별하고, MITRE ATT&CK 기반으로 공격행위를 분류한 후 대응 및 Detection Tuning까지 수행하는 End-to-End SOC 실무형 포트폴리오 구축을 목적으로 한다.